

SIMS Role-Based Access Control (RBAC) Guide

Welcome to the Student Intern Management System (SIMS) security and access guide! This document provides a comprehensive A-to-Z breakdown of every user role in the system, exactly what dashboards they can see, and what actions they are permitted to perform.

This guide is designed to be easy to understand for students, administrators, and new developers.

The 7 Core Roles of SIMS

SIMS is built around a hierarchy of 7 distinct roles. Access cascades downwards, meaning higher-level roles automatically inherit the permissions of the roles beneath them.

1. 👑 Super Admin & Admin

The ultimate controllers of the system.

- **Dashboards:** Full System Dashboard, Payroll, Assets, AI Center, Tasks, Attendance, Intern Mgmt.
- **Special Permissions:**
 - Manage the entire organization (Organizations, Departments, Teams).
 - Register new staff members and assign their roles.
 - Full financial access (Manage Payments and Payroll records).

2. 🏢 Manager

Focused on high-level operational oversight and staff coordination.

- **Dashboards:** Management Dashboard, Assets, Reports, Interns, Departments, Teams.
- **Special Permissions:**
 - Can view and manage staff (`canManageUsers`).
 - Can view Payroll records (`canViewPayroll`).
 - Cannot register new staff or manage core organization settings.

3. 🎯 Lead & SME (Subject Matter Expert)

Focused on guiding groups of interns, assigning work, and evaluating performance.

- **Dashboards:** Intern Management, Project & Task Dashboard, Attendance Dashboard, AI Center.
- **Special Permissions:**
 - Create and assign tasks (`canCreateTask`).
 - Verify completed tasks (`canVerifyTask`).
 - Approve or reject Intern Documents (`canApproveDocs`).
 - Approve Intern Leave requests (`canApproveLeave`).

4. 🧑 Mentor

Focused strictly on 1-on-1 intern growth and daily guidance.

- **Dashboards:** Mentoring Dashboard, AI Center.
- **Special Permissions:**
 - Create and verify tasks for their assigned interns.
 - Approve Intern Leave requests.
 - *Cannot* approve formal Intern Documents (this is reserved for Leads/SMEs/Managers).

5. 🧑 Intern

The core users of the platform.

- **Dashboards:** Intern Self-Service Dashboard (My Portal).
- **Special Permissions:**
 - **Read-Only System:** Interns are completely isolated in their own portal. They cannot see other interns, staff, or system settings.
 - **Capabilities:** They can log attendance, submit tasks, upload documents, apply for leave, chat with the AI Assistant, and view their own performance metrics.

Permission Matrix Quick Reference

Action / Permission	Admin	Manager	Lead	SME	Mentor	Intern
Manage Organization Settings	☑	✗	✗	✗	✗	✗
Register New Staff	☑	✗	✗	✗	✗	✗
View/Manage Payroll	☑	☑	✗	✗	✗	✗
Manage Departments & Teams	☑	☑	✗	✗	✗	✗
Approve Formal Documents	☑	☑	☑	✗	✗	✗
Approve Leave Requests	☑	☑	☑	☑	✗	✗
Create & Verify Tasks	☑	☑	☑	☑	☑	✗
Access AI Center	☑	☑	☑	☑	☑	☑
Self-Service Actions Only	✗	✗	✗	✗	✗	☑

Technical Implementation Details (For Developers)

The RBAC system in SIMS is deeply integrated into both the React frontend and the Django backend.

Frontend Security (`permissions.js`)

The frontend uses route protection components (`<ProtectedRoute>`) to physically prevent unauthorized users from loading restricted Dashboard Shells.

- e.g., `<ProtectedRoute roles={MANAGER_ROLES}>` ensures only Admins and Managers can render the `AdminLayout`.

Backend Security (Django REST Framework)

The frontend UI is just the first layer. The Django backend uses custom DRF permission classes (`IsAdminUser`, `IsManager`, `IsStaffOrManager`) to strictly reject any unauthorized API requests, ensuring absolute data security even if someone tries to bypass the UI.